

Industrial Security (Master)

Solution Sheet – Section 01 Firmware Reverse Engineering

Exercise 1.1 – Source and Verify

Award marks for: clear chain-of-custody (where, when, who), reproducible hash, and a defensible legal basis (open licence, vendor partner agreement, ownership). Bonus: noting whether the vendor publishes a detached signature, not just a hash.

Exercise 1.2 – Triage

Expected artefacts:

- Architecture line from `binwalk -A` (e.g. ARM, EABI5 version 1 (SYSV)).
- Offsets for `uImage` / `kernel` / `squashfs` / `cpio` sections.
- Mounted root-FS listing key files (`/etc/passwd`, `/etc/rc.d/`, `/usr/sbin`).

Exercise 1.3 – Strings to Findings (sample answers)

- `TELNETD_PASS=admin123` in `/etc/rc.d/S50telnet` – mitigation: disable Telnet at firewall, ACL the management VLAN.
- PEM private key in `/etc/ssl/private/server.key` that is byte-identical to the one shipped in firmware v1.4 (long-known): mitigation: replace certificate via vendor tool or rotate at HTTPS reverse proxy.
- Backdoor account `factory:Fact0ry` hard-coded in `/sbin/lighttpd`: mitigation: WAF rule to block requests with that Authorization header, monitor for usage.

Exercise 1.4 – Ghidra Mini-Reverse (mark scheme)

- Symbol identification (login, parser, OTA verifier).
- Correct CWE classification (CWE-798 hard-coded, CWE-22 path traversal, CWE-787 OOB write).
- Patch proposal that is more than “add input validation” – name the function and the check.

Exercise 1.5 – Disclosure Letter (mark scheme)

A passing letter is short, specific, factual, and contains: product + version + hash, minimal repro, requested timeline, contact, optional PGP. It does not include exploit code or threats.